

SyncBase

NIST AI Risk Management Framework Assessment

Intended Use, Risk Assessment, Model Card & Governance Documentation

Version 1.0 | September 2026

Prepared by: Sameer Athili

Aligned to NIST AI RMF 1.0 (January 2023)

1. Intended Use Statement

1.1 System Description

SyncBase is a cross-functional alignment tool for Product Managers. It provides a communication layer alongside existing project management tools (Jira, Azure DevOps, Asana) to track decision rationale, stakeholder synchronization, and cross-team accountability through a unified RAID log (Risks, Actions, Issues, Decisions).

1.2 AI Components

SyncBase incorporates one AI feature and one rule-based feature.

AI-Powered: Alignment Scanner

The Alignment Scanner reads across all of a project's artifacts — timeline updates, decisions, action items, risks, and issues — grouped by author and team. It sends the full artifact set to an LLM (Claude, Anthropic) via API with a prompt that asks: identify where stated assumptions diverge across groups. The model returns one to three conflicts, each citing the specific artifact from each party as evidence, and a recommended action for the PM to consider. The scanner is advisory — it surfaces conflicts and suggests responses, but the PM decides whether and how to act. It is governed by a precision-over-recall design philosophy (see Section 4): it surfaces only conflicts with strong evidence, not every possible inconsistency.

Rule-Based: Weekly Digest Generator

The Weekly Digest is deterministic string assembly — it is not LLM-powered. It reads structured project data (updates, overdue actions, decisions, stakeholder sync status) and concatenates them

into a formatted summary using template logic. No model call is made. It reports what was entered; it does not detect conflicts, interpret data, or generate novel text.

1.3 Intended Users

- Product Managers at small to mid-size organizations (5–50 person product teams)
- Project leads managing cross-functional initiatives across Engineering, Design, Marketing, and Operations
- Stakeholders consuming project status updates (read-only consumption of digests and scanner output)

1.4 Intended Context of Use

- Internal project communication, not external customer-facing or regulatory communication
- The Alignment Scanner is advisory — it surfaces potential conflicts and suggests actions, but the PM decides whether and how to act. No automated action is taken on scanner output.
- Supplementary to, not a replacement for, human judgment on project status and stakeholder alignment
- Prototype / pre-production deployment; not intended for safety-critical or regulated-industry decision-making

1.5 Out-of-Scope Uses

SyncBase is NOT designed or validated for:

- Automated decision-making without human review
- Performance evaluation of team members or stakeholders
- Legal, financial, or compliance reporting
- Safety-critical systems, healthcare, or any domain where a misclassification could cause physical or financial harm
- Replacing direct human communication on high-stakes project decisions

1.6 Known Limitations

Technical Limitations

- Client-side storage only — data does not sync across devices or browsers; each browser instance is isolated
- No real-time API integration with Jira/ADO — import is file-based (CSV/JSON export), not live-synced
- The Alignment Scanner operates on locally stored project data only; it has no access to Slack, email, or meeting transcripts
- No authentication federation (SSO/OAuth). SyncBase has no server-side user store; the prototype writes an unsalted 32-bit digest of the password to local storage so the plaintext is not persisted. This is obfuscation, not password hashing, and provides no meaningful security. Production requires server-side credential handling.

AI-Specific Limitations (Alignment Scanner)

- The scanner can only detect conflicts present in artifacts the user has entered. It has no access to Slack, email, meeting transcripts, or any system beyond what is stored in SyncBase.
- The scanner may identify false conflicts where two artifacts use different language for the same underlying assumption, or miss real conflicts expressed in similar language.
- The LLM may hallucinate — generating plausible-sounding conflicts that are not supported by the input data. Each conflict cites evidence artifacts, but the PM must verify the citations are accurately represented.
- The scanner posts the full artifact set to the Anthropic API, via a server-side proxy, on every scan. Project data including update text, decision rationale, stakeholder names, and action items is transmitted to the LLM provider. The proxy protects the API key; it does not reduce what is sent.
- No adversarial robustness testing has been performed. Crafted inputs in update or decision fields could manipulate scanner output.
- The scanner has no memory across invocations — it cannot track whether a conflict was previously flagged and resolved.

Digest Limitations (Rule-Based)

- The digest is deterministic string assembly, not AI. Its limitations are structural: it may omit items if the project has more data than the template accommodates, and it cannot interpret, weigh, or prioritize — it lists what exists.
- The digest cannot verify the accuracy of user-entered data. If a status update is wrong, the digest reproduces that error.

2. Risk Assessment: NIST AI RMF Core Functions

The following assessment maps SyncBase's AI components against the four core functions of the NIST AI Risk Management Framework: Govern, Map, Measure, and Manage.

2.1 GOVERN — Organizational Governance

The Govern function establishes the organizational context, policies, and accountability structures for AI risk management.

GV-1: Organizational AI Policies

Status: Partial implementation

SyncBase is a single-developer prototype. There is no formal organizational AI policy framework. However, the following governance choices have been explicitly documented:

- The precision-over-recall decision (Section 4) was made deliberately and its tradeoffs documented
- The Alignment Scanner is advisory — it surfaces conflicts and suggests actions, but no automated action is taken without PM review
- The digest is rule-based string assembly and contains no AI-generated language or recommendations

GV-2: Roles and Responsibilities

Current state: Single developer (product owner, developer, and AI governance lead). In a production context, the following roles would be separated:

- AI Product Owner — defines acceptable performance thresholds and use-case boundaries
- ML Engineer — maintains model integration, monitors output quality
- Data Steward — manages data retention, access controls, and privacy compliance
- End-User PM — responsible for reviewing scanner output and verifying cited evidence before acting (human-in-the-loop)

GV-3: Stakeholder Engagement

Completed: Feedback collected from the Director of PMO and IT Planning at Seaspan (enterprise shipbuilding). Key insights: the tool fits smaller, fast-paced organizations with tool flexibility; without integration consuming project and team details from existing tools, SyncBase creates double-entry overhead rather than removing it. This feedback directly shaped the import feature.

GV-4: Risk Tolerances

Risk Category	Tolerance	Rationale	Mitigation
Scanner flags a false conflict	Medium	Wastes PM investigation time but does not cause harm	Precision-over-recall design limits false positives. PM verifies cited evidence before acting.
Scanner misses a real conflict	Medium	Accepted per governance decision (Section 4)	Output states it is not exhaustive. PMs retain independent judgment and other communication channels.
Scanner hallucinates a conflict	Low	Erodes trust in the tool	Prompt requires cited evidence. PM verifies citations against source artifacts. Any hallucination triggers prompt revision.
Project data exposed via API call	Low	Project data may contain strategic or personnel information	Production version: data minimization review, send only required fields. Current: full artifact set transmitted.
Data loss from client-side storage	Medium	Prototype limitation	Export feature (CSV/JSON) available; production version would use server-side persistence
Unauthorized data access	Low	Project data may be sensitive	Password-protected accounts; production would add SSO, RBAC, and encryption at rest

2.2 MAP — Context and Risk Identification

The Map function identifies and contextualizes AI risks relative to the system's purpose, stakeholders, and operating environment.

MP-1: AI System Context

Dimension	Assessment
AI Task Type	Cross-document conflict detection — reading across structured project artifacts from multiple authors and teams to identify where stated

	assumptions diverge
Automation Level	Advisory with human-in-the-loop. Scanner surfaces conflicts and suggests actions; PM reviews, verifies evidence, and decides whether to act. No automated action.
Impact Tier	Low. Incorrect scanner output causes wasted PM investigation time but no safety, financial, or legal harm. A missed conflict may have downstream project impact but the scanner is advisory, not a control.
Data Sensitivity	Medium. Project data may contain strategic plans, personnel information, revenue targets, and partner details. All data remains client-side in prototype.
Affected Populations	Internal stakeholders only. No consumer-facing impact. No protected-class implications.

MP-2: Risk Identification

Risks were identified through structured analysis of failure modes across the AI component's lifecycle:

ID	Risk	Likelihood	Impact	Description
S-01	Hallucinated conflict (Scanner)	Medium	High	LLM generates a plausible-sounding conflict between two parties that is not supported by the input artifacts. PM investigates a non-issue and loses trust in the tool.
S-02	False conflict from language mismatch (Scanner)	High	Medium	Two artifacts use different terminology for the same assumption. Scanner flags a divergence that does not exist. Most likely failure mode.
S-03	Missed real conflict (Scanner)	Scanner output displays: "This is not exhaustive. Review the full RAID log for complete coverage." The caveat renders on both the conflicts-found and the no-conflicts-found states, so it is present whenever the scanner speaks. Verified in application source	High	Scanner fails to detect a genuine assumption divergence because both parties express it in similar language. Accepted risk per precision-over-recall governance decision (Section 4).

		(AlignmentView).		
S-04	Prompt injection via artifact text (Scanner)	Low	Medium	A user enters text in an update or decision field that manipulates scanner output — e.g., injecting instructions to suppress a real conflict or fabricate one.
S-05	Over-reliance on scanner output	Medium	High	PM treats scanner silence as confirmation of alignment. Develops false confidence that if SyncBase did not flag it, no misalignment exists.
S-06	Data exposure via API call (Scanner)	Server-side proxy implemented : the API key is no longer exposed in client code. Data minimisation (sending only the fields required for conflict detection rather than full artifact text) is NOT implemented .	Medium	Partial
D-01	Digest omits item (Digest, rule-based)	Medium	Low	Digest template has fixed structure. If project has more data than template slots, items are dropped. Not an AI risk — structural limitation of rule-based assembly.
D-02	Stale data in digest (Digest, rule-based)	Low	Low	If data is not updated, digest presents outdated information as current without caveat.

2.3 MEASURE — Metrics and Evaluation

The Measure function defines how AI system performance, trustworthiness, and risk are quantified and monitored.

MS-1: Performance Metrics

Alignment Scanner (AI):

Metric	Definition	Target / Status
Conflict precision	% of flagged conflicts that are genuine assumption divergences (not false positives)	Target: >80%. Not yet measured — requires production use with

	from language differences)	PM verification logging.
Evidence accuracy	% of cited evidence artifacts that actually support the claimed assumption. Checks whether the scanner accurately represents what each party said.	Target: 100%. Manual review required per scan.
Hallucination rate	% of conflicts that reference artifacts or assumptions not present in the input data	Target: 0%. Any hallucinated conflict is a critical failure.
PM action rate	% of flagged conflicts where the PM takes an action (schedules meeting, updates artifact, reassigns). Measures whether output changes behaviour.	Baseline unknown. To be tracked in production.
Time to resolution	Average time between a conflict being flagged and the PM marking it resolved or dismissed	No target set. Diagnostic metric — long resolution times may indicate low-value flags.

Weekly Digest (rule-based — no AI metrics required):

Metric	Definition	Target / Status
Completeness	% of critical items (blockers, overdue actions) included in digest output	Deterministic — depends on template structure, not model behaviour.
Time saved	Reduction in minutes spent writing weekly status updates	Not measured. No baseline was captured and no instrumentation exists to measure this. Stated here as an open metric rather than a result.

MS-2: Trustworthiness Characteristics (per NIST AI RMF)

Characteristic	Assessment	Rating
Valid & Reliable	Scanner output is consistent for the same input data within a single model version. Not validated against ground-truth alignment assessments from PMs. Conflict citations can be verified against source artifacts.	Partial
Safe	Low-risk application. No safety-critical outputs. Failure mode is PM inconvenience, not harm.	Adequate
Secure & Resilient	The Alignment Scanner calls the LLM through a server-side proxy endpoint; the API key is held in the server environment and is never present in client code or transmitted to the browser. The scanner still transmits the full project artifact set (update text, decision rationale, stakeholder names, action items) to the model provider on each scan; data minimisation is planned, not implemented (S-06). No adversarial or prompt-injection robustness testing has been performed (S-04). Credential storage in the prototype is not production-grade (Section 1.6).	Partial
Accountable & Transparent	Scanner output cites specific artifacts as evidence, allowing PM to verify each claim. Output includes caveat that it is not exhaustive. This governance document exists.	Adequate
Explainable	Each flagged conflict cites the specific artifact from each party. PM can read the cited updates and assess whether the claimed divergence is real. No opaque scoring or weighting.	Adequate

Privacy-Enhanced	All data stored client-side. No telemetry. Alignment Scanner sends full project artifact text (including stakeholder names and decision rationale) to Anthropic API on each scan. Production version needs data minimization review: send only the fields required for conflict detection, not the full artifact set.	Partial
Fair (Bias-Managed)	Not applicable — scanner detects assumption divergence between teams, not individuals. It does not make decisions about people.	N/A

2.4 MANAGE — Risk Treatment and Monitoring

The Manage function addresses how identified risks are treated, monitored, and communicated throughout the AI system's lifecycle.

MG-1: Risk Treatment Plans

Alignment Scanner (AI):

Risk	Treatment	Implementation	Owner	Status
S-01	Evidence-grounded generation	Prompt requires each conflict to cite a specific artifact title from each party. PM verifies citations against source data.	Developer	Implemented
S-02	Confidence filtering	Prompt instructs model to return only high-confidence conflicts. Maximum 3 results. Precision-over-recall design (Section 4).	Developer	Implemented
S-03	Explicit coverage caveat	Scanner output displays: "This is not exhaustive. Review the full RAID log for complete coverage." The caveat renders on both the conflicts-found and the no-conflicts-found states, so it is present whenever the scanner speaks. Verified in application source (AlignmentView).	Developer	Implemented
S-04	Input sanitization	Production version should sanitize artifact text before LLM ingestion. Not implemented in prototype.	Developer	Planned
S-05	Human-in-the-loop	Scanner output is displayed for PM review. No automated action is taken. PM decides whether to act on each conflict.	Product Owner	Implemented
S-06	Data minimization	Server-side proxy implemented: the API key is no longer exposed in client code. Data minimisation (sending only the fields	Developer	Partial

		required for conflict detection rather than full artifact text) is NOT implemented.		
--	--	---	--	--

Weekly Digest (rule-based — no AI-specific treatments required):

Risk	Treatment	Implementation	Owner	Status
D-01	Template expansion	If project data exceeds template capacity, production version should paginate or summarize by category.	Developer	Planned
D-02	Staleness indicator	Digest should flag when source data is >7 days old. Not yet implemented.	Developer	Planned

MG-2: Monitoring Plan

Alignment Scanner monitoring (production deployment):

- Conflict audit: review 100% of scanner outputs for the first 30 days. After stabilization, sample 25% monthly. Compare flagged conflicts against PM assessment of whether the conflict was real.
- Hallucination tracking: log every conflict where the cited evidence artifact does not support the claimed assumption. Any hallucination triggers prompt revision.
- PM action rate: track what percentage of flagged conflicts result in PM action. If <30% of conflicts lead to action after 60 days, the precision threshold is too low — tighten the prompt.
- False confidence monitoring: quarterly survey asking PMs 'Have you ever been surprised by a misalignment that SyncBase did not flag?' Track frequency to assess whether recall is acceptably low.
- Incident log: any reported case where a scanner output led to a wrong action or a missed conflict contributed to a project failure is documented, root-caused, and addressed within 48 hours.

Digest monitoring: no AI-specific monitoring required. Standard QA on template output.

MG-3: Decommission Criteria

The Alignment Scanner should be decommissioned or redesigned if:

- Conflict precision drops below 50% for two consecutive months (more than half of flagged conflicts are false positives)
- Any hallucinated conflict (evidence citation that does not exist in the artifact set) occurs more than once in 30 days after prompt revision
- PM action rate drops below 10% for 60 consecutive days (output is not changing behaviour)
- A scanner miss directly contributes to a material project failure and post-mortem finds the conflict was detectable from available artifacts
- PMs report reduced trust in the tool due to false positives, as measured by satisfaction rating dropping below 3.0 for two consecutive quarters

The digest is rule-based and does not require AI-specific decommission criteria. It can be disabled through project settings at any time.

3. Model Card

Adapted from Mitchell et al. (2019) 'Model Cards for Model Reporting.'

Field	Details
Model Name	SyncBase Alignment Scanner
Model Type	LLM-based cross-document analysis. API call to third-party model, not fine-tuned. (Note: the Weekly Digest feature is rule-based string assembly and is not covered by this model card.)
Upstream Model	Claude Sonnet (Anthropic) via API. Model identifier is pinned in application source (claude-sonnet-4-6); it is not negotiated at call time. Changing it is a code change and is treated as a change requiring re-review under MG-2. No custom fine-tuning.
Task	Read across a project's full artifact set (updates, decisions, actions, risks, issues) grouped by author and team. Identify where stated assumptions diverge across groups. Return 1-3 high-confidence conflicts with cited evidence from both parties and a recommended action.
Input Data	Project updates (title, status, author, date, body), action items (title, owner, due date, priority, status), decisions (title, rationale, impact, alternatives), risks (title, likelihood, impact, mitigation), issues (title, severity, description), stakeholder list (name, role, team, sync status). Full set transmitted to Anthropic API per scan.
Output	JSON array of 1-3 conflicts. Each contains: title, severity, description, two parties with their assumed position and the specific artifact cited as evidence, and a recommended PM action. Empty array if no high-confidence conflicts found.
Training Data	None (no fine-tuning). Relies entirely on upstream model's pre-training and prompt engineering.
Evaluation Data	4 sample projects with realistic PM scenarios. Manual review against source data. No formal test set or benchmark.
Ethical Considerations	No decisions about individuals. No protected-class data processed. Scanner is advisory — PM reviews output and decides whether to act. Output includes explicit caveat that it is not exhaustive.
Known Failure Modes	False conflicts from linguistic differences rather than real assumption divergence; missed conflicts when both parties use similar language for different meanings; hallucinated conflicts when input data is sparse; inability to detect sarcasm or hedging in user-written artifacts.
Recommended Use	PM reviews flagged conflicts, verifies cited evidence against source artifacts, and decides whether to act. Scanner output is a starting point for investigation, not a conclusion.
Unsuitable Use	Automated action without review; regulatory or compliance reporting; performance evaluation; any context where a false conflict or missed conflict has material consequences without human verification.

4. Governance Decision: Precision Over Recall

4.1 Decision Statement

SyncBase's Alignment Scanner is governed by a deliberate precision-over-recall design philosophy: the system prioritizes surfacing fewer, more accurate and actionable conflicts over surfacing every possible inconsistency. This is a governance choice, not a technical limitation.

4.2 Context

The Alignment Scanner reads across a project's full artifact set and uses an LLM to identify where assumptions diverge across teams. The model will find many potential inconsistencies in any sufficiently complex project — different teams use different language, reference different timelines, and frame priorities differently. The design question is not whether the model can find mismatches; it is which mismatches are worth a PM's attention.

Feedback from the Director of PMO and IT Planning at Seaspan shaped the broader product direction: without integration to existing tools, the product creates overhead rather than removing it. This reinforced a general design principle — every feature must reduce PM workload, not add to it. Surfacing 15 low-confidence conflicts that each require investigation would violate that principle.

This framing exposed a fundamental design tension in AI-assisted project management tools:

- High recall, low precision: surface everything, let the PM sort it out. Risk: alert fatigue, PM ignores the tool, and the important signal drowns in noise.
- High precision, low recall: surface only high-confidence, high-impact items. Risk: miss a genuine issue that the model wasn't confident enough to flag.

4.3 Decision Rationale

We chose precision over recall for the following reasons:

1. The cost of false positives is higher than the cost of false negatives in this context

A PM who receives 15 'misalignment alerts' and finds that 10 are irrelevant will stop reading the alerts entirely. The tool becomes noise, not signal. A missed alert is a single-instance failure; alert fatigue is a systemic failure that disables the entire tool.

2. PMs already have compensating controls for false negatives

PMs have meetings, Slack channels, 1:1s, and their own pattern recognition. If the AI misses something, the PM may catch it through other means. But if the AI cries wolf, it erodes trust in the one channel that was supposed to reduce their workload.

3. Trust is the adoption bottleneck, not coverage

For a new tool with no track record, every false positive is a withdrawal from the trust bank. The tool must earn credibility by being right when it speaks, not by speaking about everything.

4.4 Tradeoffs — What This Decision Costs

This governance choice has real consequences that are accepted, not ignored:

What We Gain	What We Lose
Higher PM trust in scanner output — when it flags	Some genuine issues will not be surfaced — the PM

something, it matters	must still exercise independent judgment
Lower alert fatigue — PMs engage with the tool instead of dismissing it	Coverage gaps may exist in complex multi-team projects with many parallel workstreams
Faster adoption curve — tool feels useful from day one, not noisy from day one	A missed high-impact issue could be attributed to the tool, even though the tool never claimed complete coverage
Cleaner signal for stakeholders — scanner output is focused, not exhaustive	PMs may develop false confidence that 'if SyncBase didn't flag it, it's fine' — an over-reliance risk (S-05)

4.5 Mitigations for Accepted Risks

- Explicit framing: the scanner output states "This is not exhaustive. Review the full RAID log for complete coverage." on both the conflicts-found and no-conflicts-found states. The no-conflicts state is the higher-risk case for over-reliance (S-05), so the caveat is shown there deliberately rather than only alongside findings.
- Adjustable threshold: production version should allow PMs to set their own sensitivity (e.g., 'show me more' vs. 'show me only critical items'), making the precision/recall tradeoff user-configurable.
- Escalation path: if a PM discovers a missed issue, they can flag it, and the system logs the miss for prompt improvement. This creates a feedback loop that improves recall over time without sacrificing precision.
- Periodic recall audit: quarterly review of conflicts the scanner missed (identified by comparing scanner output to actual project outcomes) to ensure recall does not degrade below acceptable levels.

4.6 Review Cadence

This governance decision will be reviewed:

- After 30 days of production use (initial calibration)
- Quarterly thereafter
- Immediately if a missed item contributes to a material project failure

The review will assess whether the precision threshold remains appropriate or whether the balance should shift toward higher recall based on accumulated evidence.

Document prepared by: **Sameer Athili**

Date: September 2026

Framework reference: NIST AI RMF 1.0 (AI 100-1, January 2023)

Applicable to: SyncBase v1.5 — Alignment Scanner

5. Document Control

5.1 Verification Basis

Every control marked Implemented in Section 2.4 was verified against SyncBase application source at the version stated below, rather than asserted from design intent. Controls that are designed but not built are marked Planned. Controls that are partially built are marked Partial and state what remains.

5.2 Change Log

Version	Date	Change
1.0	Sep 2026	Initial assessment. Scanner and digest scoped, risks registered, precision-over-recall governance decision documented.
1.1	Sep 2026	Correction pass following source-code verification. (1) The S-03 coverage caveat was marked Implemented but did not exist in the application; it has since been built and the claim is now accurate. (2) The Alignment Scanner was moved to a server-side proxy so the API key is not exposed in client code; MS-2 rewritten accordingly and S-06 moved from Planned to Partial. (3) Model card corrected: the model identifier is pinned in source, not selected at call time. (4) Section 1.6 corrected: the prototype obfuscates stored passwords, it does not hash them in any security-meaningful sense. (5) The unsubstantiated digest time-saving figure was removed and restated as unmeasured.

5.3 Outstanding Items

- S-04 Input sanitisation against prompt injection. Designed, not implemented.
- S-06 Data minimisation. The proxy protects the API key, but the full artifact set is still transmitted on every scan.
- MS-1 No performance metric has been measured. Conflict precision, evidence accuracy and hallucination rate each require production use with PM verification logging before any figure can be stated.
- D-01 and D-02 Digest template expansion and staleness indicator. Designed, not implemented.
- Credential handling. Requires a server-side user store; out of scope while the prototype is client-side only.

Applicable to: SyncBase v1.5.1 — Alignment Scanner
Framework reference: NIST AI RMF 1.0 (AI 100-1, January 2023)